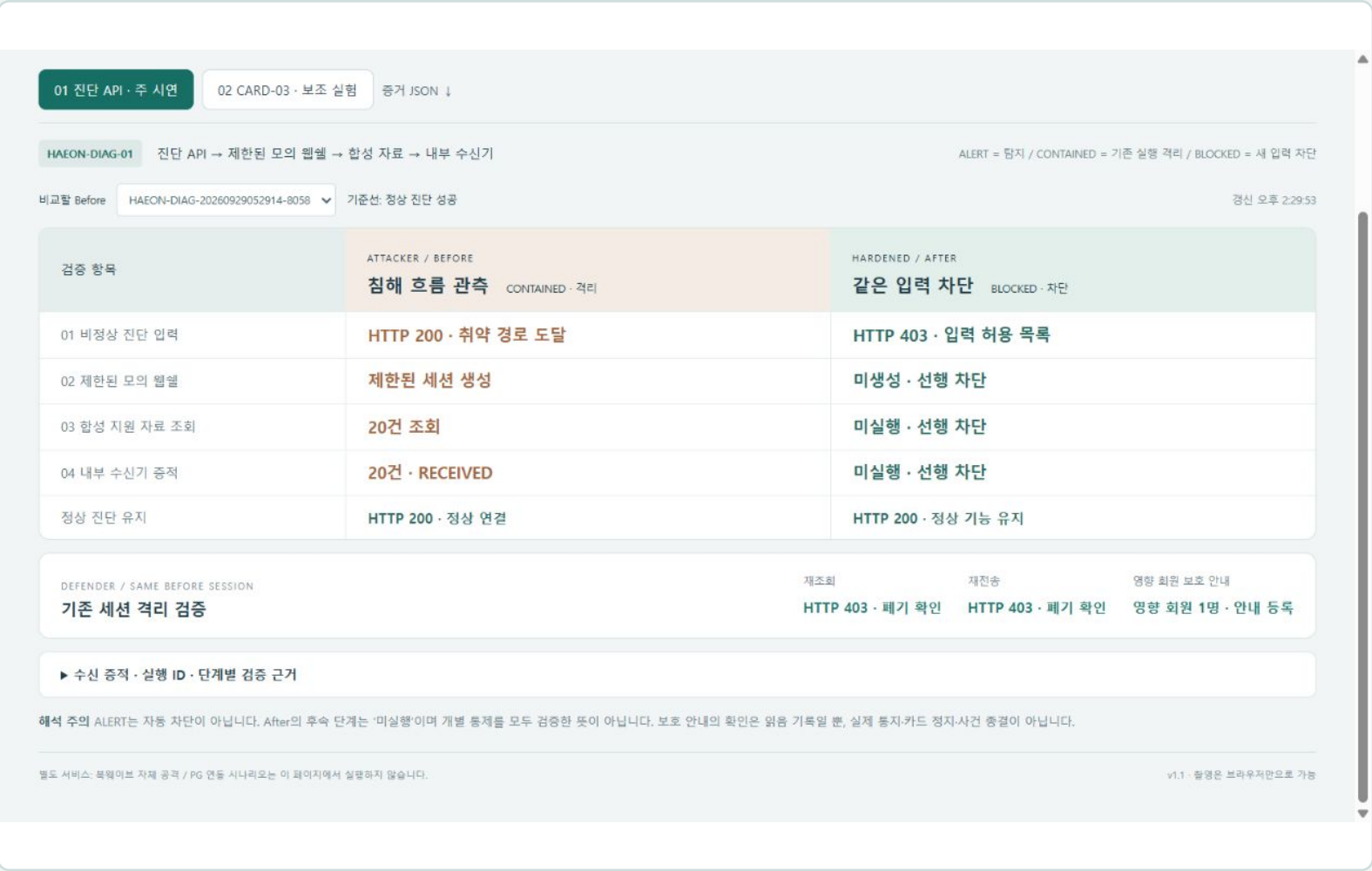


해온카드, 화면을 따라가며 촬영하세요.

정상 사용자 → 공격자 관점 → 방어자 대응 → 개선 검증. 약 3~4분 + 보조 실험 40초.



이번 영상에서 보여줄 것

주 시연 · HAEON-DIAG-01

진단 API에서 제한된 모의 웹shell로 이어지는 흐름과 합성 자료 20건의 내부 수신, 기존 세션 격리, 새 입력 차단.

보조 · CARD-03

별도 합성 MySQL 장부에서 동시 승인 경쟁 조건과 행 잠금의 차이를 비교.

학생에게 콘솔을 공개하지 않습니다.
콘솔 주소는 촬영 PC의 loopback이며 학생용 도메인으로 404를 반환합니다.

말하지 않을 것

실제 악성 웹shell 설치·임의 OS 명령·실제 카드정보 유출을 재현한 것이 아닙니다. 북웨이브 자체 공격과 PG 연동 시나리오는 이번 해온카드 영상에서 실행하지 않습니다.

녹화 버튼을 누르기 전에

현재 PC에는 수정·빌드가 적용된 상태입니다. 다음 촬영에서는 연결 확인 → 상태 초기화 → 로그인 준비부터 시작합니다.

미리 열어 둘 브라우저 탭

A 해온카드 메인	http://127.0.0.1:8090/
B 시연 데스크	http://127.0.0.1:8094/
C 가맹점	http://127.0.0.1:8090/merchant/
D 마이페이지	http://127.0.0.1:8090/mypage
E 결과 전용	http://127.0.0.1:8094/filming.html?view=results

기존 상세 콘솔은 /index.html로 유지됩니다. 촬영에는 B/E 화면을 권장합니다.

기동은 촬영 전에 완료

```
WSL bash에서 프로젝트 경로로 이동한 뒤
docker compose --env-file .env up -d --build
docker compose ps
```

주의: up 없는 docker compose -d --build는 잘못된 명령입니다.
기존 DB를 새로 배포할 때는 011_card03_lab.sql 적용이 별도로 필요합니다.
현재 환경은 적용 완료. 초기화를 위해 down -v를 사용하지 마세요.

로그인은 촬영 전 또는 편집으로 제외

가맹점: labmart / LabMart!2026
영향 회원: haeon01 / Haeon!2026
비교 회원: haeon02 / Haeon!2026

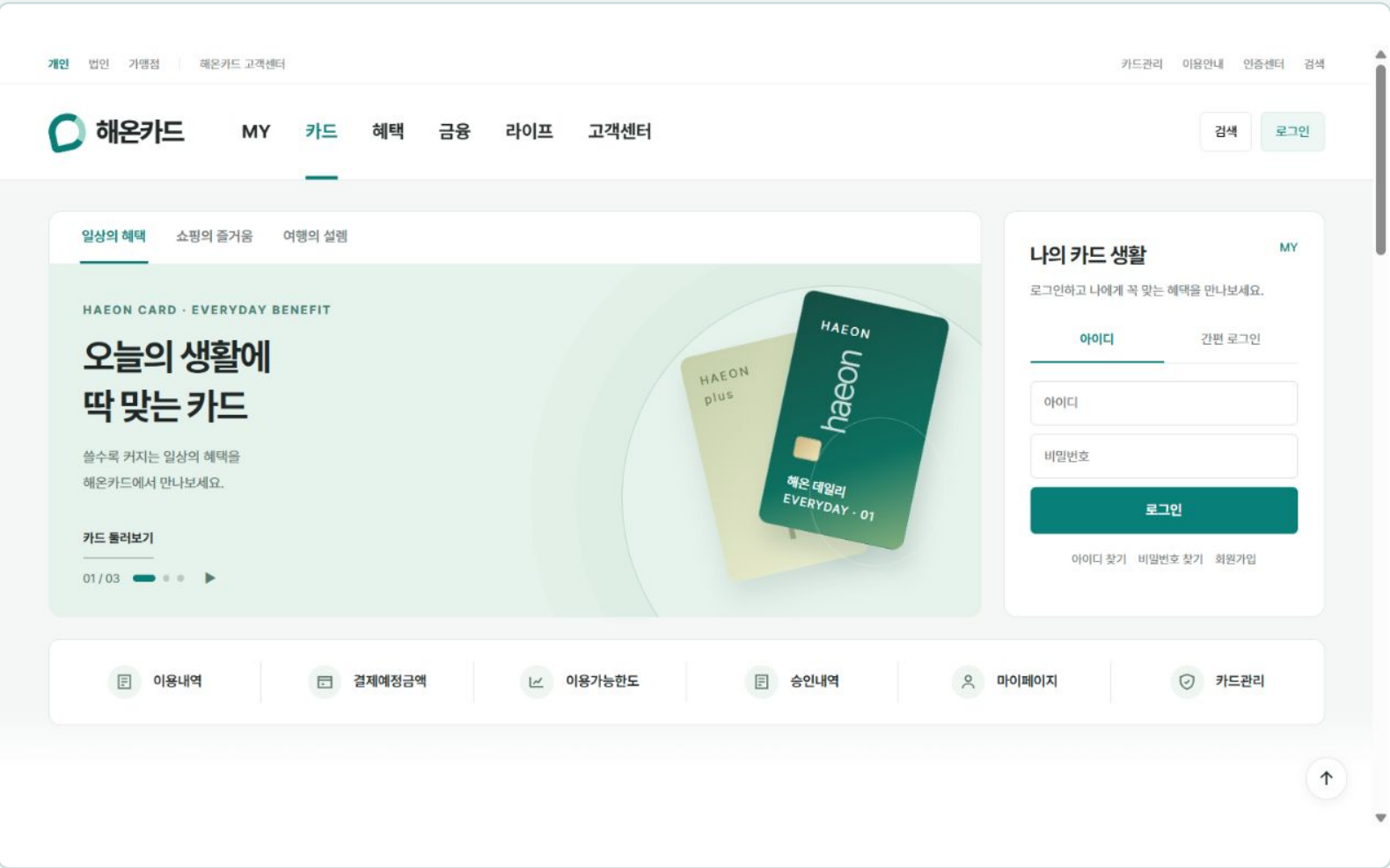
모두 합성 실습 계정입니다. 임의 입력이나 공격 명령을 준비할 필요는 없습니다.

미리 지정된 값

등록 대상: 해온마트
주 시연 자료: 합성 지원 자료 20건
CARD-03: 10만원 한도, 6만원 요청 2건
실행 ID·응답 시간·SHA-256은 실행마다 달라질 수 있습니다.

해온카드 메인으로 시작합니다.

탭 A → 탭 B. 사이트가 누구의 서비스인지 먼저 보여줍니다.



01 탭 A의 메인 화면을 5초 정도 보여줍니다.

02 탭 B, 시연 데스크로 전환합니다. “진단 API · 주 시연” 탭을 유지합니다.

03 가맹점 정상 진단을 보여주기 위해 탭 C로 이동합니다.

완료 확인

복웨이블가 아니라 해온카드 화면인지 확인합니다. 공격 터미널은 열지 않아도 됩니다.

녹화 팁

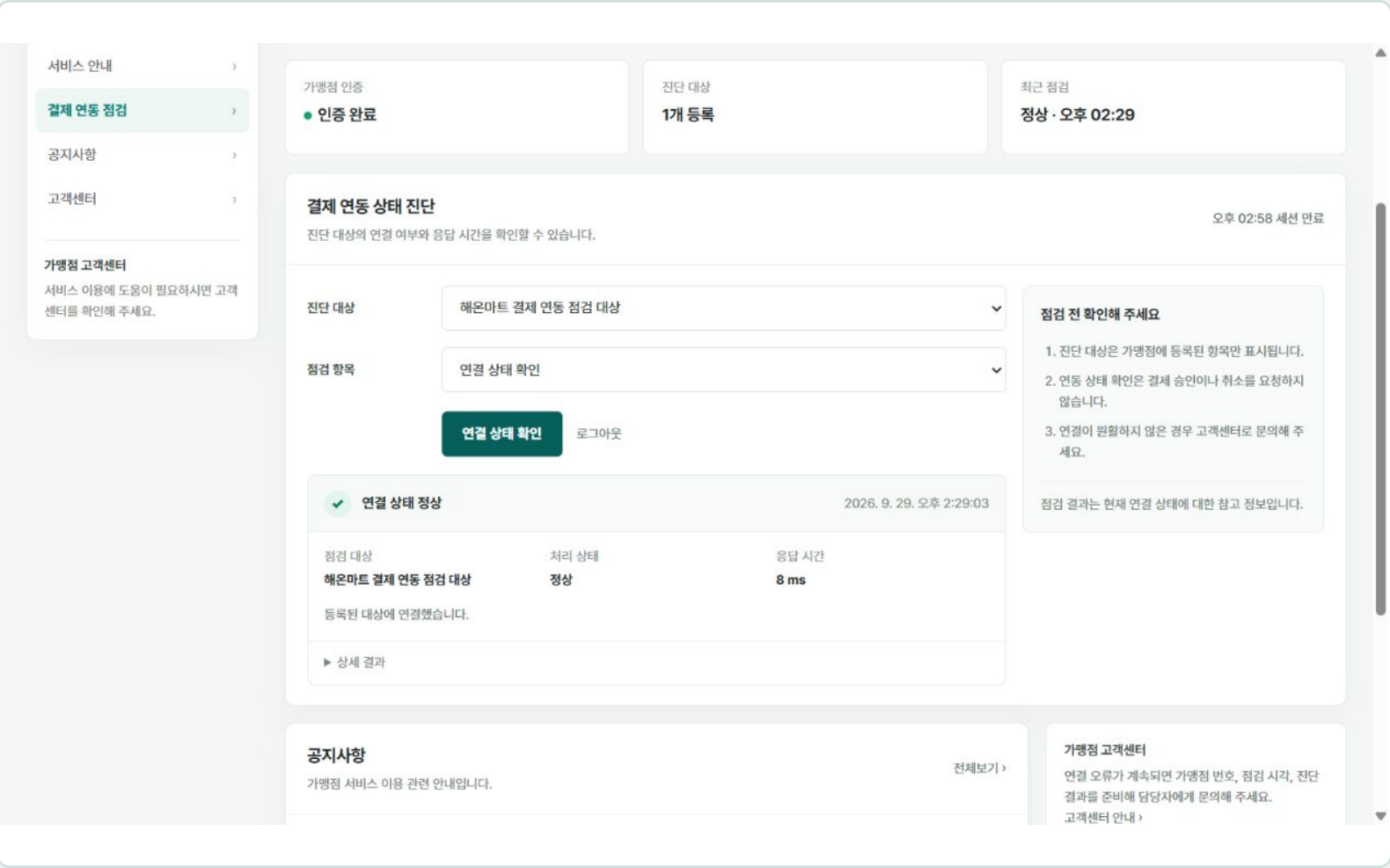
버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사

“해온카드의 가맹점 결제 연동 진단 기능을 대상으로, 침해 흐름과 대응 후 차단 여부를 확인하겠습니다.”

가맹점의 정상 사용을 먼저 보여줍니다.

탭 C에서 실제 정상 연결 진단 → 탭 B에서 비교 기준선 기록.



01 가맹점 계정으로 로그인합니다. 대상은 “해온마트 결제 연동 점검 대상”입니다.

02 “연결 상태 확인”을 누릅니다. 결과의 정상 상태와 응답 시간을 보여줍니다.

03 탭 B로 돌아와 “정상 진단”을 누릅니다. 기준선 성공 표시를 기다립니다.

완료 확인

가맹점의 “연결 상태 정상”, 데스크의 “기준선: 정상 진단 성공”. 두 화면의 실행은 별도 요청입니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대서 “가맹점은 등록된 대상의 연결 상태만 점검할 수 있습니다. 먼저 정상 요청이 정상 처리되는 기준선을 확보합니다.”



HAEON CARD

SECURITY VALIDATION / 2026

해온카드

가맹점

마이페이지

상세 콘솔

발표자 전용 · LOCAL

PRESENTATION DESK

침해 재현에서, 차단 검증까지.

실제 실습 API의 결과를 비교합니다. 임의 OS 명령·실제 카드정보·외부 유출은 사용하지 않습니다.

01 진단 API · 주 시연

02 CARD-03 · 보조 실험

증거 JSON ↓

HAEON-DIAG-01

진단 API → 제한된 모의 웹캠 → 합성 자료 → 내부 수신기

ALERT = 탐지 / CONTAINED = 기존 실행 격리 / BLOCKED = 새 입력 차단

비교할 Before

HAEON-DIAG-20260929052914-8058

기준선: 정상 진단 성공

경신 오후 2:29:19

검증 항목	ATTACKER / BEFORE 침해 흐름 관측 ALERT · 탐지	HARDENED / AFTER 같은 입력 차단 미실행
01 비정상 진단 입력	HTTP 200 · 취약 경로 도달	미실행
02 제한된 모의 웹캠	제한된 세션 생성	미실행
03 합성 지원 자료 조회	20건 조회	미실행
04 내부 수신기 증적	20건 · RECEIVED	미실행
정상 진단 유지	HTTP 200 · 정상 연결	미실행

DEFENDER / SAME BEFORE SESSION

기존 세션 격리 검증

재조회

재전송

영향 회원 보호 안내

미검증

미검증

미등록

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰.
비밀번호.개발자도구는 영상에 담지 않습니다.

05

조회와 수신을 다른 근거로 설명합니다.

탭 E의 “수신 증적 · 실행 ID · 단계별 검증 근거”를 펼칩니다.

검증 항목

ATTACKER / BEFORE
침해 흐름 관측
ALERT · 탐지

HARDENED / AFTER
같은 입력 차단
미실행

01 비정상 진단 입력	HTTP 200 · 취약 경로 도달	미실행
02 제한된 모의 웹	제한된 세션 생성	미실행
03 합성 지원 자료 조회	20건 조회	미실행
04 내부 수신기 증적	20건 · RECEIVED	미실행
정상 진단 유지	HTTP 200 · 정상 연결	미실행

DEFENDER / SAME BEFORE SESSION

기존 세션 격리 검증

재조회
미검증

재전송
미검증

영향 회피 보호 안내
미등록

▼ 수신 증적 · 실행 ID · 단계별 검증 근거

BEFORE RUN
HAEON-DIAG-20260929052914-8058

AFTER RUN
-

1. 시나리오 실행 ID 발급 · 성공
2. 가명점 지원 격정 인증 · 성공
3. 등록 진단 대상 확인 · 성공
4. 진단 요청 전송 · 성공 / HTTP 200
5. 제한된 모의 웹 세션 생성 · 관측
6. 합성 지원 자료 조회 · 관측
7. 내부 수신기로 전송 · 관측

TRANSFER ID
TRANSFER-HAEON-DIAG-20260929052914-8058

수신 페이로드 SHA-256
e24fc9cdaf224287bd47a02009526a8e3b45bdf2b8e9012c50442a776e8af00

01 하단 수신 증적을 펼칩니다. 필요하면 아래로 스크롤합니다.

02 Before 실행 ID와 TRANSFER ID, 수신 페이로드 SHA-256을 보여줍니다.

03 세션 토큰이 담긴 원시 응답 파일이나 개발자도구는 열지 않습니다.

완료 확인

콘솔은 응답의 실행 ID·전송 ID·건수·해시 형식을 확인합니다. 지원 서비스는 실제 수신 영수증의 해시까지 대조합니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사 “조회 20건만으로 유출 성공이라고 판단하지 않습니다. 내부 수신기의 RECEIVED와 전송 ID, 건수, 해시 일치를 별도로 확인합니다.”

대응한 뒤, 같은 세션으로 다시 시도합니다.

탭 B의 “대응 및 재접근 검증” → 탭 E의 기존 세션 격리 결과.

01 진단 API · 주 시연02 CARD-03 · 보조 실험증거 JSON ↓

HAEON-DIAG-01

진단 API → 제한된 모의 웹shell → 합성 자료 → 내부 수신기

ALERT = 탐지 / CONTAINED = 기존 실행 격리 / BLOCKED = 새 입력 차단

비교할 Before

HAEON-DIAG-20260929052914-8058

기준선: 정상 진단 성공

경신 오후 2:29:31

검증 항목	ATTACKER / BEFORE	HARDENED / AFTER
	침해 흐름 관측CONTAINED · 격리	같은 입력 차단미실행
01 비정상 진단 입력	HTTP 200 · 취약 경로 도달	미실행
02 제한된 모의 웹shell	제한된 세션 생성	미실행
03 합성 지원 자료 조회	20건 조회	미실행
04 내부 수신기 증적	20건 · RECEIVED	미실행
정상 진단 유지	HTTP 200 · 정상 연결	미실행

DEFENDER / SAME BEFORE SESSION

기존 세션 격리 검증

재조회

HTTP 403 · 패기 확인

재전송

HTTP 403 · 패기 확인

영향 회원 보호 안내

영향 회원 1명 · 안내 등록

▶ 수신 증적 · 실행 ID · 단계별 검증 근거

해석 주의 ALERT는 자동 차단이 아닙니다. After의 후속 단계는 '미실행'이며 개별 통계를 모두 검증한 뜻이 아닙니다. 보호 안내의 확인은 읽음 기록일 뿐, 실제 통지·카드 정자·사건 종결이 아닙니다.

별도 서비스: 복원미브 자체 공격 / PG 연동 시나리오는 이 페이지에서 실행하지 않습니다.

v1.1 · 화면은 브라우저만으로 가능

01 탭 B에서 현재 Before 실행의 “대응 및 재접근 검증”을 누릅니다.

02 탭 E에서 기존 세션의 재조회·재전송이 각각 HTTP 403인지 확인합니다.

03 CONTAINED와 영향 회원 안내 등록을 보여준 뒤 탭 D로 이동합니다.

완료 확인

재조회 403 + 재전송 403이 있어야 격리 검증 완료입니다. 세션 폐기 표시만으로 재접근까지 검증됐다고 말하지 않습니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

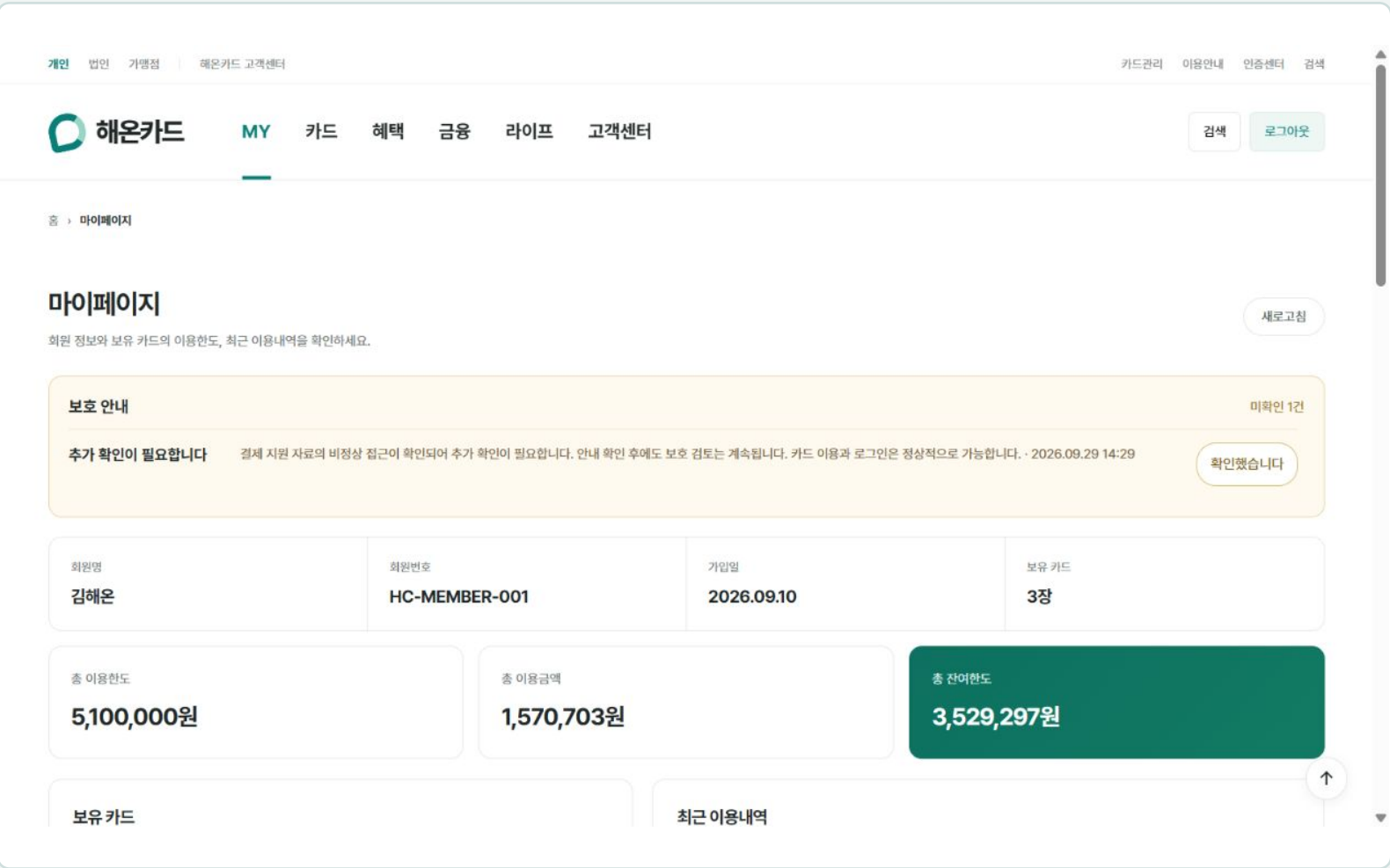
읽을 대사 “운영자 대응으로 이 실행의 세션을 폐기했습니다. 방금 사용한 같은 세션으로 다시 조회하고 전송해도 모두 403으로 거절됩니다.”

HAEON CARD / 촬영자 전용 / v1.1 / 2026.09.29

07

마이페이지의 보호 안내를 보여줍니다.

탭 D. 영향 회원 haeon01로 로그인 또는 새로고침.



- 01 영향 회원으로 로그인해 “보호 안내 / 추가 확인이 필요합니다”를 보여줍니다.
- 02 안내가 안 보이면 페이지의 “새로고침”을 누릅니다. Before 실행과 대응을 확인합니다.
- 03 “확인했습니다”는 선택 사항입니다. 눌러도 읽음 기록만 남는다고 설명합니다.

완료 확인

미확인 1건과 카드 이용·로그인 정상 안내. 비교가 필요할 때만 haeon02에 안내가 없음을 별도로 보여줍니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사 “자료 접근이 확인된 합성 회원에게 추가 확인 안내가 등록됐습니다. 실제 문자 발송이나 카드 정지가 아니라, 영향 회원 보호 안내 화면입니다.”

같은 입력은 막고, 정상 진단은 유지합니다.

탭 B의 After 실행 → 탭 E의 최종 비교 화면.

01 진단 API · 주 시연

02 CARD-03 · 보조 실험

증거 JSON ↓

HAEON-DIAG-01

진단 API → 제한된 모의 웹shell → 합성 자료 → 내부 수신기

ALERT = 탐지 / CONTAINED = 기존 실행 격리 / BLOCKED = 새 입력 차단

비교할 Before

HAEON-DIAG-20260929052914-8058

기준선: 정상 진단 성공

경신 오후 2:29:53

검증 항목	ATTACKER / BEFORE	HARDENED / AFTER
	침해 흐름 관측 CONTAINED · 격리	같은 입력 차단 BLOCKED · 차단
01 비정상 진단 입력	HTTP 200 · 취약 경로 도달	HTTP 403 · 입력 허용 목록
02 제한된 모의 웹shell	제한된 세션 생성	미생성 · 선행 차단
03 합성 지원 자료 조회	20건 조회	미실행 · 선행 차단
04 내부 수신기 증적	20건 · RECEIVED	미실행 · 선행 차단
정상 진단 유지	HTTP 200 · 정상 연결	HTTP 200 · 정상 기능 유지

DEFENDER / SAME BEFORE SESSION

기존 세션 격리 검증

재조회
HTTP 403 · 패기 확인

재전송
HTTP 403 · 패기 확인

영향 회원 보호 안내
영향 회원 1명 · 안내 등록

▶ 수신 증적 · 실행 ID · 단계별 검증 근거

해석 주의 ALERT는 자동 차단이 아닙니다. After의 후속 단계는 '미실행'이며 개별 통계를 모두 검증한 뜻이 아닙니다. 보호 안내의 확인은 읽음 기록일 뿐, 실제 통지카드 정지·사건 종결이 아닙니다.

별도 서비스: 복원미보 자체 공격 / PG 연동 시나리오는 이 페이지에서 실행하지 않습니다.

v1.1 · 설명은 브라우저만으로 가능

01 탭 B로 돌아와 “After 실행”을 누릅니다. 이전 세션 검증을 마쳐야 활성화됩니다.

02 탭 E에서 오른쪽 HTTP 403과 뒤 단계의 “미실행”을 설명합니다.

03 맨 아래 정상 진단 HTTP 200을 함께 보여주고 주 시연을 마칩니다.

완료 확인

After BLOCKED와 정상 진단 200을 모두 확인합니다. 대응은 기존 세션 격리, After는 미리 구성한 강화 경로 검증입니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사 “개선된 입력 허용 목록에서는 같은 비정상 입력이 403으로 차단됩니다. 뒤 단계는 실행되지 않았고, 정상 진단은 계속 성공합니다.”

동시 승인 실험은 별도로 촬영합니다.

탭 B → “02 CARD-03 · 보조 실험” → 동시 승인 Before / After 실험.

CARD-03 / ISOLATED LAB

동일 합성 카드 · 서로 다른 거래 2건 · 실제 MySQL 트랜잭션

현재 승인 코어는 이미 행 잠금을 사용합니다. 이 화면은 별도 합성 장부에서 위약한 동시 읽기와 가산된 행 잠금을 비교하는 고독을 실행하며, 승인 코어 자체 또는 복웨이브+Mock PG 통합시험의 결과가 아닙니다.

동시 승인 Before / After 실험

한도 100,000원 / 요청별 60,000원 / 서로 다른 TX-1, TX-2

검증 완료

BEFORE · 동시 과거 값 읽기

2건 승인 / 120,000원

실험 장부 사용액 120,000원 · 잔여 -20,000원

거래	반영 시 잔여 한도	결과
TX-1	100,000원	승인
TX-2	100,000원	승인

AFTER · SELECT ... FOR UPDATE

1건 승인 / 60,000원

실험 장부 사용액 60,000원 · 잔여 40,000원

거래	반영 시 잔여 한도	결과
TX-1	40,000원	한도 초과 거절
TX-2	100,000원	승인

ISOLATED LAB REGRESSION

정상·재시도 유지

정상 20,000원

승인

동일 요청 재시도

최초 결과 재사용

키 충돌 / 초과 한도

모두 거절

실행 ID: CARD03-b7e1383b-dc11-4d1e / 2026. 9. 29. 오후 2:30:05

Before는 재현성을 위해 두 읽기 시점을 동기화합니다. 결과 숫자를 고정 출력하는 애니메이션이 아닙니다. 실험 장부는 실제 회선 한도·결과 내역과 분리되어 있습니다.

별도 서비스: 복웨이브 자체 공격 / PG 연동 시나리오는 이 페이지에서 실행하지 않습니다.

v1.1 · 촬영은 브라우저에서만 가능

01 별도 합성 장부라는 범위 설명을 먼저 보여줍니다. 실행 버튼을 한 번 누릅니다.

02 Before: 서로 다른 6만원 요청 2건이 각각 과거 10만원 한도를 읽고 총 12만원 승인.

03 After: 행 잠금 뒤 최신 한도로 재판정해 1건 승인, 1건 거절. 정상·재시도 유지도 확인합니다.

완료 확인

Before 120,000원 / After 60,000원. 어느 거래가 먼저 승인되는지는 달라질 수 있습니다. 숫자는 실제 DB 결과입니다.

녹화 팁

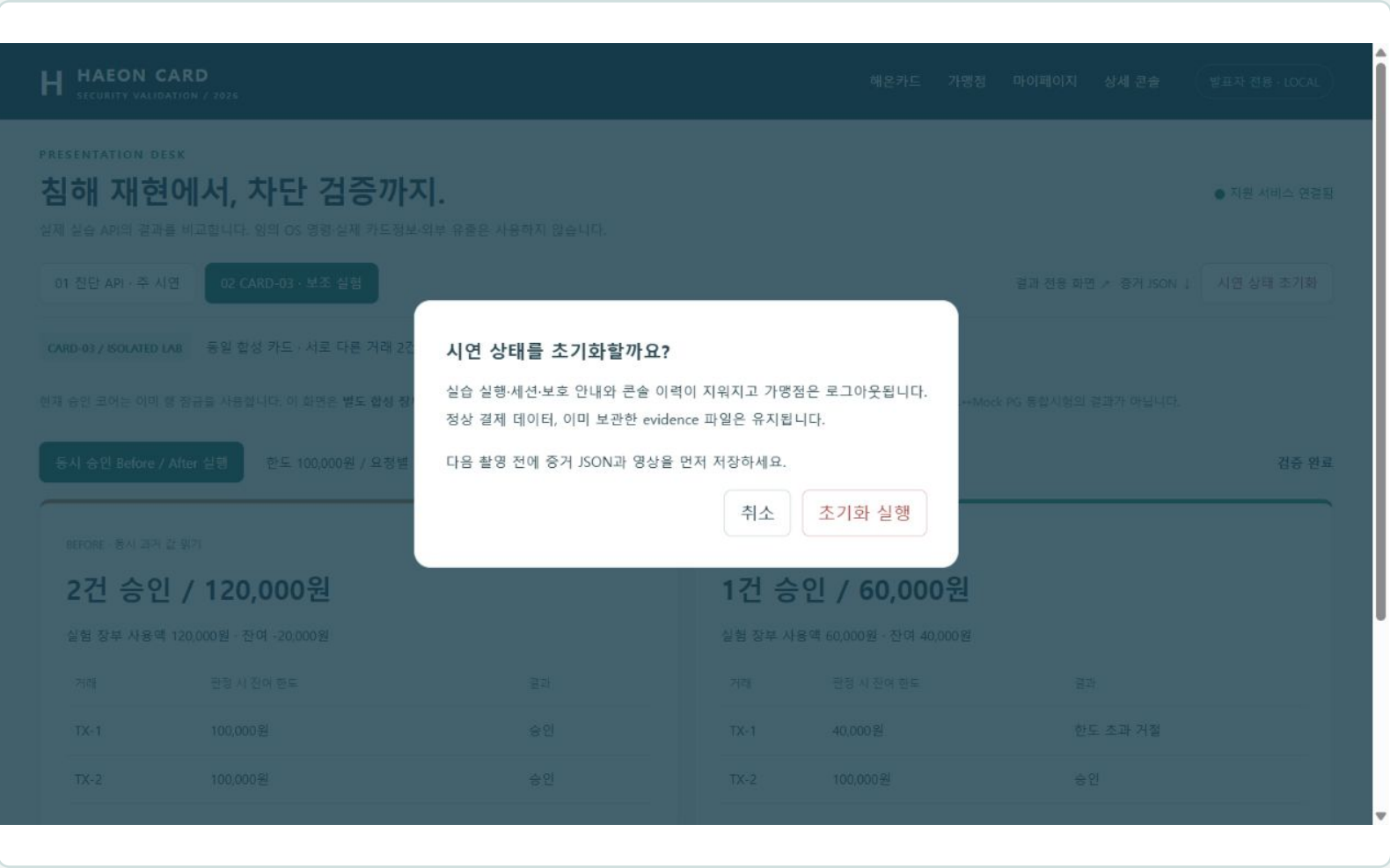
버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사

“별도 합성 MySQL 장부에서 경쟁 조건을 재현했습니다. 행 잠금 적용 후에는 한 건만 승인됩니다. 현재 승인 코어나 PG 경유 전체를 공격한 결과는 아닙니다.”

재촬영은 증거 저장 후 초기화합니다.

이번 완료 상태는 확인용으로 남겨 두었습니다. 다음 촬영 전에 직접 초기화하면 됩니다.



01 “증거 JSON ↓”로 현재 결과를 저장합니다. 영상 파일도 먼저 저장합니다.

02 “시연 상태 초기화” → 안내 확인 → “초기화 실행”을 누릅니다.

03 가맹점 로그인부터 다시 시작합니다. 정상 결제 데이터와 evidence 파일은 유지됩니다.

완료 확인

실행 이력 없음 / 보호 안내 없음 / 가맹점 재로그인. CARD-03 실험 장부는 증거로 남으며 새 비교는 새 장부로 시작합니다.

녹화 팁

버튼을 누른 뒤 결과가 바뀔 때까지 기다립니다. 토큰·비밀번호·개발자도구는 영상에 담지 않습니다.

읽을 대사 재촬영 준비 장면은 최종 영상에서 제외해도 됩니다. 초기화는 실습 상태만 정리하며, 프로젝트 폴더나 Docker 전체 데이터를 삭제하지 않습니다.

촬영 중에는 이 순서만 따라가세요.

화면 전환은 A 메인 / B 데스크 / C 가맹점 / D 마이페이지 / E 결과 전용.

1	A → B	서비스 소개	해온카드가 대상임을 명시
2	C → B	가맹점 정상 연결 → 정상 진단	기준선 성공
3	B → E	Before 실행 → 결과 설명	ALERT / 조회 20 / RECEIVED 20
4	E	수신 증적 펼치기	TRANSFER ID + SHA-256
5	B → E	대응 및 재접근 검증	같은 세션 재조회 403 / 재전송 403
6	D	영향 회원 보호 안내	추가 확인 안내 / 읽음 기록의 의미
7	B → E	After 실행 → 정상 기능 확인	입력 403 / 후속 미실행 / 정상 200
8	B · 선택	CARD-03 보조 실험	격리 장부 / 12만원 → 6만원 승인

영상 끝 문장 “탐지, 기존 세션 격리, 새 입력 차단을 구분했고 정상 진단도 유지됨을 확인했습니다.”

터미널은 필수가 아닙니다. payment-server-incident-simulation.sh는 이 해온카드 시연에 사용하지 않습니다.

막히면 확인할 것, 되돌릴 때 지킬 것

백업은 이미 만들어 두었습니다. 아래는 복원 실행이 아니라 필요할 때 참고하는 안내입니다.

촬영 중 문제

이전 콘솔이 뜸

새로고침합니다. 최신 데스크는 127.0.0.1:8094/ 또는 /filming.html입니다.

After 버튼 비활성

최근 Before를 선택하고 “대응 및 재접근 검증”을 완료합니다. 구버전 실행은 새 Before부터 시작합니다.

20건 조회, 수신은 미확인

성공으로 설명하지 않습니다. 수신기 상태·RECEIVED·전송 ID·해시를 확인하고 다시 검증합니다.

502 또는 연결 실패

docker compose ps로 서비스 상태를 봅니다. 관련 서비스를 재생성했다면 게이트웨이 reload/restart로 upstream IP를 갱신합니다.

마이페이지 안내가 안 보임

haeon01 로그인, 새로고침, 현재 Before의 대응 여부를 확인합니다. haeon02에는 안내가 없는 것이 정상입니다.

원본 폴더 + 실행 상태 백업

C:\Wstudy\Wdocker\W

bookwave-haeon-lab-backup-20260929-pre-filming

전체 1,273개 파일을 해시 비교로 확인했습니다.
.git / .env / 미커밋 파일 / 당시 evidence 포함.
_runtime에는 해온 DB 덤프와 콘솔 이력이 있습니다.
기존 Docker 이미지도 별도 태그로 보존했습니다.

소스 복원 순서

관련 서비스 중지 → 현재 폴더를 별도 이름으로 보관 → 백업을 원래 경로로 복사 → 서비스 재빌드.

백업 자체를 이동하거나 덮어쓰지 않습니다.

폴더만 교체해도 Docker DB 볼륨은 되돌아가지 않습니다. DB까지 복원하려면 현재 결과물을 다시 백업하고 RESTORE.md의 별도 절차를 따릅니다.

주의: 원본 nginx 설정으로 복원하면 이전 콘솔 공개 설정도 돌아옵니다. 학생 공개를 계속 막으려면 최신 제한 설정을 유지해야 합니다. 실제 복원 시험은 수행하지 않았습니다.

발표 자료와 실제 구현을 이렇게 맞췄습니다.

원본 슬라이드와 보안 가이드는 보존했습니다. 아래 차이는 발표 멘트와 슬라이드 캡션에 반영하세요.

HAEON-DIAG-01	문서의 주 시연 흐름 유지. 고정 실습 입력 → 제한된 세션 → 합성 20건 조화·수신 → 같은 세션 격리 확인 → 새 입력 차단 → 정상 진단 재검증.
CARD-03	현재 승인 코어는 이미 행 잠금 적용 상태. 새 화면은 별도 MySQL 합성 장부의 취약/강화 비교이며, 기존 승인 코어의 취약점 재현 또는 Mock PG 통합시험이라고 발표하지 않음.
검증과 근거	단위 검사 15개, 실제 API 회귀 검사 26개 통과. 장애·재시작 포함 검사 31개 통과. 기존 승인 코어의 승인·거절·동일 키 재시도·키 충돌·위조 결과 필드·인증 거절도 별도 확인.
촬영 화면과 증거	웹 화면은 실제 API 결과를 표시. 공개 JSON에는 세션 토큰 미포함. evidence/console, evidence/receiver, evidence/runs에 근거 보관. 현재 최종 Before/After 와 CARD-03 결과를 남겨 둠.
검증 범위 밖	실제 악성코드 설치, 임의 OS 명령, 실제 개인정보·외부 유출, 실제 통지·카드 정지, 모든 후속 방어선 검증, 기존 PG 연동 전체와 북웨이브 공격은 이 수정의 검증 범위가 아님.

참조 자료

v0.8_slides.pdf: p.23 주 시나리오 / p.27 Before-After / p.34 정상 기능 유지

security-guide-bookwave-haeon-v1.1.pdf: p.5 해온카드 / p.6 CARD-03 / p.8 통제 검증

동일 보안 가이드 HTML: #haeon / #card03 / #verify. 실제 화면 캡처: 2026.09.29 로컬 실행.